# Smokescreen incorporation design — closing the DNS-rebinding / TOCTOU SSRF gap

**Revision:** 1 **Last modified:** 2026-07-01T19:10:00Z **Status:** Design + phased incorporation plan. The gap is **demonstrated autonomously** (`tests/security/dns_rebinding_ssrf_gap.sh`, committed) and the resolved-IP-recheck fix logic is **proven** (T2 blocks all rebinding targets; `REBIND_MUT=1` proves the teeth). Actually incorporating smokescreen is **operator-gated** (§11.4.122 — adds a runtime component to the data-plane) and container-runtime-gated (§11.4.161, currently podman-blocked). **Authority:** inherits `constitution/Constitution.md` per §11.4.35. **Companion:** the gap demo `dns_rebinding_ssrf.md` · the OSS survey `../../research/vpn_lan_opensource_survey_20260701/SURVEY.md` (smokescreen = ranked recommendation #1).

---

## 1. The gap smokescreen closes

Our current egress floor matches on the **requested host / destination** at ACL-check time:

- **Squid** (`config/squid/squid.conf`) — `http_access` ACLs on the request.
- **Dante** (`config/dante/sockd.conf`) — `socks block/pass` rules on `to:` (the Phase-1 SSRF floor: RFC1918 + link-local + loopback + metadata blocked, one narrow `HELIX_BRIDGE_SUBNET` carve-out permitted above the `10/8` block).

Both evaluate a **name or a stated destination**, then connect. A hostname that resolves to a **public** IP at check time and re-resolves to an **internal** IP at connect time (DNS-rebinding / TOCTOU) slips through — the static ACL never re-checks the **actual connect-time resolved IP** against the RFC1918/metadata floor. This is the class our `dns_rebinding_ssrf_gap.sh` demonstrates (T1: hostname-only policy permits the rebinding target; T2: a resolved-IP recheck blocks it).

**Stripe smokescreen** is a purpose-built egress/CONNECT proxy that, after DNS resolution, re-validates the **resolved IP** against a deny-list (RFC1918 / link-local / loopback / metadata / user-configured CIDRs) **before** dialing — closing exactly this TOCTOU sub-class.

# 2. Incorporation options (§11.4.74 extend-don't-reimplement, §11.4.76 containers)

| Option | Placement | Pros | Cons / honest boundary |
|---|---|---|---|
| **A — smokescreen in front of Squid** (egress hop) | client → Squid → **smokescreen** → internet | single choke point for HTTP(S)-CONNECT egress; resolved-IP recheck on every CONNECT | only covers what traverses Squid (HTTP-shaped); adds one hop |
| **B — smokescreen beside Squid** (parallel CONNECT proxy) | client → **smokescreen** for CONNECT; Squid for cache/HTTP | clean separation; smokescreen owns the SSRF-sensitive CONNECT path | two proxies to operate |
| **C — resolved-IP recheck IN Dante/Squid** (no new component) | patch the existing floor | no new dependency | Dante/Squid do not natively re-validate the resolved IP; would be original work (§11.4.8), higher risk than adopting a hardened tool |

**Recommended: Option A** (smokescreen as an egress hop in front of Squid) — it reuses a hardened, purpose-built tool (§11.4.74) rather than reimplementing SSRF recheck in-house, and gives one enforcement point for the CONNECT path. Deploy on-demand via the `vasic-digital/containers` submodule (`pkg/boot/pkg/compose/pkg/health`, rootless Podman §11.4.161), config-injected (§11.4.28 — the deny-CIDR list + the narrow `HELIX_BRIDGE_SUBNET` allow are supplied from the project, never hardcoded into the tool).

# 3. Composition with the existing floor (§11.4.120 no-collapse)

Smokescreen's resolved-IP deny-list must be the **same floor** as the Dante SSRF floor: block RFC1918 + link-local (169.254/16) + loopback (127/8) + metadata (169.254.169.254), with the **one narrow `HELIX_BRIDGE_SUBNET` host carve-out** (Phase-1) as the only internal-range exception — and that carve-out stays **bridge-gated + operator-gated** (opening it before the VPN routes is a regression, §11.4.101/§11.4.133). The `ingress_allowlist_teeth.sh` + `ssrf_carveout_teeth.sh` + `dns_rebinding_ssrf_gap.sh` guards already prove the floor is narrow and non-collapsible; a smokescreen config would be validated by an analogous resolved-IP-recheck teeth test before it ships.

# 4. Honest boundary (§11.4.6)

- **HTTP(S)-CONNECT only.** Smokescreen protects the CONNECT egress path. It does **NOT** cover the **SOCKS/Dante** path nor the **L3-routed mounts** (SMB/NFS route directly over the VPN, not through a CONNECT proxy). Those need their **own** resolved-IP recheck — the Dante floor already blocks internal ranges statically, but the same TOCTOU class would need a Dante-side or resolver-side recheck to fully close. This is stated so no one reads "smokescreen adopted" as "all SSRF TOCTOU closed."
- **Not currently exploited.** The gap is in policy logic; the `10/8` carve-out it concerns is itself operator-gated and not yet opened. This is hardening, not incident response.
- **Incorporation is operator-gated** (§11.4.122 — new data-plane runtime component) and container-runtime-gated (§11.4.161 — the host podman is currently broken; see the data-plane env-block). The **design + the gap demo** are what is autonomous now.

## 5. Phased incorporation plan (tasks → subtasks)

| Phase | Task | Sub-tasks | Autonomous vs operator-gated |
|---|---|---|---|
| S0 | Gap proof (DONE) | `dns_rebinding_ssrf_gap.sh` (T1 gap / T2 fix / `REBIND_MUT`) | **Autonomous — committed** |
| S1 | Operator decision | ask keep/adopt (§11.4.66); confirm Option A | **Operator-gated** |
| S2 | Containerize | add smokescreen service decl (config-injected §11.4.28) via containers submodule; deny-CIDR floor + narrow carve from env | Autonomous design; **deploy operator-gated + podman-gated** |
| S3 | Resolved-IP-recheck teeth | a local-stub test asserting the shipped smokescreen config blocks a rebinding target + permits the carve host (mirror of the Phase-1 teeth) + `MUT` mode | Autonomous once S2 config exists |
| S4 | Wire egress path | client → Squid → smokescreen; re-run the S1/S3/S4 security guards to prove no floor collapse (§11.4.120) | **Operator-gated (live data-plane)** |
| S5 | Extend to SOCKS/L3 | design a Dante-side / resolver-side resolved-IP recheck for the non-CONNECT paths | Future work |

## 6. Bidirectional-protocol ingress note

The Phase-12 ingress surface (VPN→proxy) is governed default-deny + narrow allowlist (`ingress_allowlist_teeth.sh`). Smokescreen is an **egress** control and does not change the ingress posture; the reverse legs (NFS NLM/NSM callback, FTP active, Cast callback, adb reverse) remain gated by the ingress allowlist. The two controls are orthogonal and compose: egress resolved-IP recheck (smokescreen) + ingress default-deny allowlist (Phase 12) together bound both directions.

# Sources verified 2026-07-01

- Stripe smokescreen — https://github.com/stripe/smokescreen (README: post-resolution IP ACL, deny-list CIDRs, CONNECT proxy).
- OWASP SSRF Prevention Cheat Sheet — https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html (validate the resolved IP, not the hostname; DNS-rebinding).
- RFC 1918 (private address space) — https://datatracker.ietf.org/doc/html/rfc1918.
- RFC 3927 (link-local 169.254/16) — https://datatracker.ietf.org/doc/html/rfc3927.

*Placement specifics (in-front-of vs beside Squid), the exact deny-CIDR wiring, and the SOCKS/L3 recheck are marked* ***INFERENCE*** *(§11.4.6) pending the operator decision + a live data-plane; this document is design + a proven gap demo, not a shipped incorporation.*